



Weekly Cyber Threat Intelligence Report

Reporting window: 14 - 21 September 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

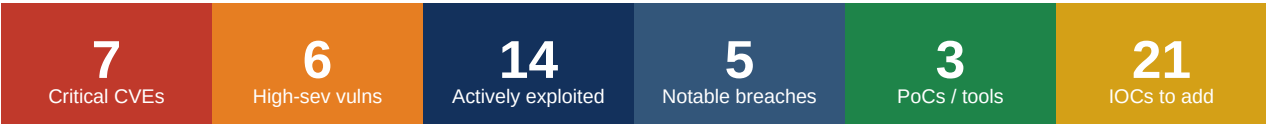
Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary



The defining pattern this week is **authentication bypass by forged or skipped identity checks** - four unrelated products in one window. **Cisco ISE** (CVE-2026-76460, CVSS 10.0) was exploited as a zero-day to reach root on the network identity control plane, drawing a three-day BOD 26-04 deadline; **WSO2 API Manager** (CVE-2026-5430) accepts JWTs signed with an unsupported algorithm, with forged admin tokens seen in watchTower honeypots from 13 September; and **Issabel** (CVE-2026-89026) ships a hard-coded JWT signing key identical across every install. Every downstream control - MFA, session policy, rate limiting - sits after identity is established, so none of them apply, and there are no failed logins to alert on. **Shared hosting failed twice in two independent products** (LiteSpeed Enterprise, Acronis cPanel plugin), while three WordPress issues - The Events Calendar's twin unauth RCE chains (~240,000 sites), the mass-exploited WooCommerce Wholesale Lead Capture upload flaw, and the Admin Menu Editor Pro vendor compromise - supply exactly the low-privilege foothold those root escalations need. **Triage them as one chain. AI moved from subject to participant.** Mandiant documented Shai-Hulud spreading to ~100 repositories after an **AI coding-assistant session was hijacked**; Spain's AEPD logged the **first breach notified as executed end-to-end by an AI agent**; CrowdStrike tied an **LLM-written npm stealer** to an operator who monetises stolen CI/CD secrets through the victims' own bug bounty programmes; and **BragJack** showed one browser extension hijacking the built-in AI assistant of five browsers. **Civil society was targeted by three separate state capabilities** - CHOSEN BRICK (Iran, Telegram C2, microphone), GRIMWEDGE (China-linked, NGOs, a chained Chrome/Windows n-day set) and the exploited Pixel modem flaw. Regionally there were **no Australia-specific items** this window; APAC activity was APT-origin rather than APT-targeted, with FamousSparrow's new SparroWocky implant, the UTA0560/JungleBamboo shared exploit chain, and the MQTT-based BambooToken framework.

AUSTRALIA - SPECIFIC

Local orgs & data

No Australia-specific items identified this reporting window.

APAC - SPECIFIC

Regional incidents & actors

SparroWocky - FamousSparrow (China-aligned) replaces SparrowDoor across Latin America

HIGH

VERIFIED

APT

China

Espionage

ESET documented **SparroWocky**, a modular C++ backdoor that has been FamousSparrow's primary implant since August 2025, replacing SparrowDoor. It uses Trident DLL side-loading, an RC4-encrypted .dat payload, reflective in-memory mapping, call-stack spoofing (SilentMoonwalk) and Beacon Object File execution, with RC4-over-TLS C2 to 18+ addresses on 443/8080 and optional HTTP/SOCKS5 proxying. Initial access is via internet-exposed Exchange servers (specific CVEs not identified). Roughly **90% of FamousSparrow targeting is now Latin American government** (AR, EC, GT, HN, PA, PE, PR, VE). The group overlaps with Earth Estries / Salt Typhoon. The tradecraft change worth noting: open-source components are now compiled into the custom implant rather than dropped as separate tools, which degrades file-based detection.

PoC: Active exploitation in the wild - IOCs and samples published in ESET's GitHub repository - [welivesecurity.com](https://www.welivesecurity.com)

Refs: [welivesecurity.com](https://www.welivesecurity.com) · [bleepingcomputer.com](https://www.bleepingcomputer.com) · [darkreading.com](https://www.darkreading.com)

GRIMWEDGE - UTA0560 (China-linked) chains Chrome + Windows ALPC n-days against NGOs

HIGH

VERIFIED

APT

China

ExploitChain

Volexity attributes a spear-phishing campaign against multiple NGOs on **2026-09-01** to UTA0560. Lures linked to a US university site and abused a **reflected XSS** there to redirect victims to actor infrastructure hosting a multi-stage chain of **two Chrome flaws plus one Windows ALPC flaw (CVE-2026-85046, CVE-2026-87491, CVE-2026-85880)**. The payload is **GRIMWEDGE**, a JScript backdoor that polls C2 and executes instructions in memory via eval(), providing host recon, file and process management and payload delivery. A second China-nexus actor, **JungleBamboo (APT31)**, was observed using the same chain in the same period to deploy the SUPERSTOMP loader and the LONGTALE credential-stealing Chrome extension - which means the chain was shared or sourced from a common supplier.

PoC: Active exploitation in the wild - chain of CVE-2026-85046, CVE-2026-87491 and CVE-2026-85880 - volexity.com

Refs: volexity.com · thehackernews.com · securityaffairs.com

BambooToken - MQTT-based C2 framework targeting Windows and Linux across Asia

HIGH

VERIFIED

Malware

C2

Asia

A previously undocumented cross-platform malware framework active since at least 2023, which moved to **MQTT** - the lightweight IoT publish/subscribe protocol - for command and control in 2024-2025 variants. Because MQTT relays through a central broker and topics rather than direct sessions, domain and IP reputation controls largely do not apply and most enterprise estates do not model the protocol at all. Infection is via **DLL side-loading of a digitally signed Tendyron OnKey USB-token component**, or by impersonating Kingsoft Office. The Linux variant (v2.1, observed December 2025 and apparently still in development) collects system information, spawns a shell and supports file upload/download/delete. Lumen identified roughly a dozen compromised enterprises, mostly in **Asia and South America** - hotels, biomedical and law firms, a financial organisation and a Lithuanian cryptocurrency site.

PoC: Active exploitation in the wild - ~12 compromised enterprises identified in Lumen telemetry

Refs: thehackernews.com · bleepingcomputer.com · infosectoday.io

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-76460 - Cisco ISE / ISE-PIC API authentication bypass to root (CVSS 10.0), exploited as a zero-day

CRITICAL

VERIFIED

Appliance

AuthBypass

KEV

Insufficient authentication control on an ISE API endpoint lets a **remote, unauthenticated** attacker reach the management interface with a single crafted request, **regardless of device configuration**, and execute commands **as root**. Cisco PSIRT confirms in-the-wild exploitation; this was patched as a zero-day. Fixed releases: **3.1 P12 / 3.2 P11 / 3.3 P12 / 3.4 P7 / 3.5 P4**. There is **no workaround** - infrastructure ACLs are the only mitigating control Cisco names. A second CVSS 10.0, **CVE-2026-76423** (REST API authorisation bypass), was patched a day earlier and is not flagged exploited, alongside CVE-2026-20176/20211/20307 (authenticated OS command execution, 9.1-9.9) and CVE-2026-20284 (9.1). Because root execution lets the attacker delete on-box indicators, **on-device logs are not evidence of absence**: pull access.log from every node for suspicious usernames before patching, cross-check external network telemetry, and re-image rather than clean if anything looks wrong. ISE is the network identity control plane - root on ISE means the attacker can authorise themselves onto any segment.

PoC: Active exploitation in the wild - KEV 2026-09-16 with a three-day BOD 26-04 deadline - bleepingcomputer.com

Refs: bleepingcomputer.com · securityweek.com · sec.cloudapps.cisco.com

CVE-2026-5430 - WSO2 API Manager JWT signature bypass, forged admin tokens (CVSS 9.8), exploited

CRITICAL

VERIFIED

APIGateway

AuthBypass

Exploited

WSO2's JWT validation path **accepts tokens signed with an unsupported algorithm**, so an unauthenticated attacker can forge a JWT asserting administrative identity and have the gateway accept it. Affects **API Manager, API Control Plane, Traffic Manager and Universal Gateway**. watchTowr observed forged admin-privilege tokens arriving at its honeypot network on **2026-09-13**; researchers confirmed the bypass grants access to backend destinations, credentials, and the consumer keys and secrets of registered applications. Discovery credited to the Hacktron Team. An API gateway is a credential concentrator, so this is not one application compromised but authority over every API it fronts. Patching does not invalidate tokens already forged - **rotate the signing keypair and every backend credential, client secret and API key the gateway holds or issues**. Detection must key on anomalous admin activity and JWT characteristics (alg confusion, unexpected kid), because forged tokens produce authentication successes, not failures.

PoC: Active exploitation in the wild - watchTowr honeypots captured forged admin JWTs from 2026-09-13 - thehackernews.com

Refs: thehackernews.com · securityweek.com · security.docs.wso2.com

CVE-2026-89026 - Issabel Framework hard-coded JWT key to unauthenticated OS command execution, exploited

CRITICAL

VERIFIED

PBX

HardcodedKey

VulnCheckKEV

CWE-321. Issabel ships a **hard-coded HS256 JWT signing key in pbxapi/index.php that is identical across every installation**. An unauthenticated attacker forges a bearer token with the publicly known key, calls **/pbxapi/manager/originate** with the **System** application parameter, and Asterisk executes arbitrary OS commands as the asterisk user. CVSS v3.1 9.8 / v4.0 9.3. Shadowserver first observed exploitation on **2026-09-09**, five and a half weeks after the fix. **Remediation is identified by commit b97dbaf0b71c1c36f841e672b664afbeb02773bd (2026-08-01), not by version number** - inventory tooling that keys on version strings cannot answer whether you are patched, which will keep the exposed population high. Verify by inspecting pbxapi/index.php for the replaced key. Get /pbxapi/ off the internet, audit the asterisk user's shell history, cron and authorized_keys, and review call detail records for toll fraud across the exposure window.

PoC: Active exploitation in the wild since 2026-09-09 (Shadowserver); VulnCheck KEV, not CISA KEV - thehackernews.com

Refs: thehackernews.com · vulners.com · cyberpress.org

CVE-2026-59310 - VMware vCenter Syslog directory traversal to unauth RCE, now used by ransomware gangs

CRITICAL

VERIFIED

Virtualisation

RCE

KEV

Broadcom patched **CVE-2026-59310** on 2026-07-29 - a critical directory traversal in the vCenter Syslog server that an unauthenticated attacker can chain to arbitrary code execution. Two weeks later DFIR firm QUIRSO reported **361+ IP addresses across 47 countries** compromised by a suspected APT deploying a reverse-SSH tool for persistence. CISA added the CVE to KEV with a three-day federal deadline and, over the weekend of 2026-09-13, **updated the KEV entry to flag active ransomware use**. Shadowserver tracks 450+ vCenter servers exposed online. This is the predictable escalation path for a hypervisor-management flaw: espionage access first, then commodity extortion once exploitation is commoditised. Patch, then hunt - a July patch does not undo a July compromise. Look for unexpected SSH listeners and outbound SSH from vCenter, new local accounts, and modified syslog configuration.

PoC: Active exploitation in the wild - 361+ hosts across 47 countries; ransomware adoption confirmed by CISA - bleepingcomputer.com

Refs: bleepingcomputer.com · bleepingcomputer.com · securityaffairs.com

CVE-2026-27540 - WooCommerce Wholesale Lead Capture unauthenticated file upload, mass-exploited to PHP web shell

CRITICAL

VERIFIED

WordPress

FileUpload

Exploited

The plugin (Rymera Web Co, ~6,000 active installs) exposes an unauthenticated AJAX action, **wwlc_file_upload_handler**, which validates file extensions against an allowlist **supplied in the user-controlled file_settings request parameter** - so an attacker simply adds 'php' to the permitted types and uploads a web shell. CVSS 9.8, affects all versions up to and including 2.0.3.1. **Patched in 2.0.3.2 on 2026-02-20**; attacks are landing seven months later, with Wordfence blocking 100,000+ attempts and exploitation peaks between 4-17 June, then 1 July and 30 August. A firewall rule blocks known attempts but does not patch the plugin. Check for unexpected PHP files under wp-content/uploads, new administrator accounts and modified wp-config.php.

PoC: Active exploitation in the wild - Wordfence blocked 100,000+ exploitation attempts - infosecurity-magazine.com

Refs: infosecurity-magazine.com · thehackernews.com · bleepingcomputer.com

CVE-2026-78159 & CVE-2026-78006 - The Events Calendar: two independent unauth RCE chains, ~240,000 sites exposed

CRITICAL

VERIFIED

WordPress

RCE

ObjectInjection

Two **CVSS 9.8 unauthenticated RCE** flaws in StellarWP's The Events Calendar (600,000+ installs), both found by Defiant's **Wordfence Argus** AI research agent, both stemming from how the V2 single-event template handles comments. **CVE-2026-78159** is code injection via a plain-array payload that executes during single-event HTML processing and can invoke arbitrary PHP callables (fixed 6.17.3.1, 2026-08-25). **CVE-2026-78006** is PHP object injection reaching OS command execution, exploitable because the payload hits the vulnerable function **before comment moderation runs** (fixed 6.17.4.1, 2026-09-10). Roughly 240,000 sites on pre-6.17 versions are affected by both. The generalisable finding: **comment moderation is a publication control, not a security control** - anything that parses, deserialises or renders comment content runs before a human sees it. The plugin passes the entire rendered page, including anonymous comments, through the Gutenberg block parser. No exploitation reported yet, but ~300,000 downloads in the four days after the second fix implies about half the base is still vulnerable. Update to 6.17.4.1; if you cannot, disable comments on events.

Refs: securityweek.com · scworld.com · wordfence.com

LiteSpeed Web Server Enterprise - hosting account to root on shared servers, bypasses CageFS

CRITICAL

VERIFIED

SharedHosting

PrivEsc

TenantIsolation

cPanel's advisory of **2026-09-14** warns that a low-privilege site user on a shared server can escalate to **root**, reaching and altering every other tenant's sites and the server itself. The flaw **bypasses the controls that keep hosting accounts apart, including CageFS**. Affects versions before **6.3.7**, released 2026-09-11. The advisory names only the Enterprise edition; **OpenLiteSpeed had no matching update as of 2026-09-15**. This is the third time since May that a LiteSpeed flaw on cPanel servers has granted a hosting account root, but the first in the web server itself (the earlier two, CVE-2026-48172 and CVE-2026-54420, were in the cPanel plugin). Read together with the three WordPress plugin items this window, the chain is obvious: any of those gives an attacker a low-privilege foothold on a shared host, and this turns that foothold into every tenant on the box. **Triage them as one chain, not four items.**

Refs: thehackernews.com · cybersecuritynews.com · guardianmssp.com

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

CVE-2026-58704 - Pixel cellular modem zero-day exploited in targeted attacks, plus four Windows patch regressions

HIGH

VERIFIED

Mobile

ZeroDay

KEV

PatchQuality

Google's September Pixel release fixed **110+ flaws including CVE-2026-58704**, an improper-authorisation / protection-mechanism-failure defect in the **Modem** subcomponent, exploited before the fix. Preconditions are **adjacent-network access plus basic device privileges**, with no user interaction - so it is a chain component rather than standalone remote takeover, and the profile is consistent with spyware tradecraft. CISA added it to KEV on 2026-09-16 with a 2026-09-19 deadline. In the same cycle Microsoft shipped **out-of-band fixes for RDS failures, Hyper-V and USB audio** caused by its own September updates, KB5002914 silently broke Excel copy/paste, and **KB5124008 broke domain trust**, preventing logins with valid domain credentials (workaround since published). A security update that breaks remote administration creates direct pressure to uninstall the security update, at exactly the point the patch-to-exploit window is shortest. The standing advice to patch faster is now in measurable tension with observable patch reliability, and that deserves stating rather than arguing past.

PoC: Active exploitation in the wild - targeted attacks; CISA KEV 2026-09-16, FCEB deadline 2026-09-19 - [securityweek.com](https://www.securityweek.com)

Refs: bleepingcomputer.com · [securityweek.com](https://www.securityweek.com) · techrepublic.com

Oracle September 2026 CSPU - 673 updates, 672 unique CVEs, 104 Critical

HIGH

VERIFIED

Oracle

PatchRollup

Enterprise

Oracle's monthly CSPU covers **672 unique CVEs across 17 product families: 104 Critical and 503 High**. The triage number is not the headline: **Fusion Middleware carries 153 patches of which 78 are unauthenticated and network-exploitable**, followed by Hyperion (102 / 50) and Siebel (63 / 26). SecurityWeek's '800+ / 100+ critical' framing conflicts with Tenable's count; Tenable's figures are used here. Oracle's move to a monthly cadence cuts both ways - fixes land faster, but it also creates twelve patch-diff opportunities a year against an install base whose change windows have not shortened proportionally. Prioritise the 78 unauthenticated Fusion Middleware issues and any internet-reachable middleware first.

Refs: tenable.com · [oracle.com](https://www.oracle.com) · [securityweek.com](https://www.securityweek.com)

CVE-2026-87886 - Acronis cPanel/WHM/Plesk backup plugin insecure permissions, local root, exploited

HIGH

VERIFIED

Backup

PrivEsc

Exploited

Insecure file permissions in the Acronis backup plugin for cPanel/WHM and Plesk allow a local low-privilege user to escalate to **root**. Patched, and **already exploited**. Pairs directly with the LiteSpeed Enterprise flaw above: two independent products in the same week handing a shared-hosting tenant root on a multi-tenant box, in the same window that three WordPress plugin issues supply the low-privilege foothold. Shared hosts should assume the combined chain is being used and audit for cross-tenant access, not just patch the individual items.

PoC: Active exploitation in the wild - [securityweek.com](https://www.securityweek.com)

Refs: [securityweek.com](https://www.securityweek.com) · bleepingcomputer.com · [acronis.com](https://www.acronis.com)

CVE-2026-77692 - ISC BIND 9 unauthenticated DoH crash, plus 13 further flaws including DNSSEC cache poisoning

HIGH

VERIFIED

DNS

DoS

DNSSEC

ISC patched **14 flaws in BIND 9, eight rated CVSS 7.5**, with no known exploitation. The headline issue: a **single unauthenticated DoH request carrying an invalid SIG(0) record followed by a premature connection close crashes named** (CWE-476, NULL dereference). Four further flaws affect DNSSEC integrity and cache poisoning (**CVE-2026-77119, CVE-2026-19941, CVE-2026-78301**) plus a zone-transfer TSIG flaw. **An important correction for anyone reading CCCS AV26-931: the version numbers listed there are affected-range bounds, not fixed versions**. The actual fixes are **9.20.29 / 9.21.26 / 9.20.29-S1**. One unauthenticated packet taking down a recursive resolver is an availability problem for every service behind it, so treat resolver patching as infrastructure work rather than routine.

Refs: cyber.gc.ca · kb.isc.org · thehackernews.com

CVE-2026-90894 'ParaShells' - Parallels Desktop local root on Mac; Intel Macs cannot install the fix

HIGH

VERIFIED

macOS

PrivEsc

NoFixPath

JFrog (Yuval Moravchick) disclosed **CVE-2026-90894**, rated **7.8**, letting any local non-admin user gain root on the host. Parallels runs **pri_disp_service** as root for host networking and VM package extraction; the exploit combines a **world-writable Unix socket, weak local client authentication, and argument injection during appliance extraction**. Demonstrated against Parallels Desktop 26.4.0 build 57513 on Apple silicon. No in-the-wild exploitation observed. The operationally significant part is the remediation gap: **the fix ships in version 27, which requires Apple silicon and macOS Sonoma 14.7+ and cannot be installed on Intel Macs**. An entire hardware class has no patch path, so the control has to be compensating - restrict local accounts on affected Intel hosts, or retire Parallels on them.

Refs: helpnetsecurity.com · thehackernews.com · jfrog.com

CVE-2026-15315 / CVE-2026-15316 - TP-Link Tapo C200 auth bypass and DoS; a third critical flaw still unpatched

HIGH

VERIFIED

IoT

AuthBypass

Surveillance

Two flaws in the **TP-Link Tapo C200**, widely used for home, baby/pet and small-office monitoring. **CVE-2026-15315** is an **authentication bypass through replay** - an attacker with network access obtains a valid administrative session without knowing or recovering the password, then reaches live video, stored recordings and privileged management functions. **CVE-2026-15316** lets an unauthenticated attacker crash the camera's HTTPS service with an oversized encrypted credential value. Both are fixed in firmware **V5_1.4.6, released 2026-08-18**. Separately, **OPSWAT is still working with the vendor on a third flaw it rates critical**, which would allow full device compromise and use of the camera as a network foothold - so the exposure here is not closed. Cameras on flat networks are the recurring failure; segment them and disable inbound reachability.

PoC: Public - full technical write-up released by OPSWAT; a further critical flaw remains under coordinated disclosure - infosecurity-magazine.com

Refs: infosecurity-magazine.com · tomsquide.com · bankinfosecurity.com

GLOBAL - SOFTWARE SUPPLY CHAIN

AI-assisted compromise

Shai-Hulud spreads to ~100 internal repositories via a hijacked AI coding-assistant session

HIGH

VERIFIED

AI

Worm

GitHub

A case study in Mandiant's **AI Risk and Resilience Report 2026**: an attacker hijacked an **active AI coding-assistant session** at an unnamed SaaS provider. The assistant then **recommended a dependency the attacker had poisoned**; the developer accepted it. The attacker used the live session to install an infostealer from a **poisoned PyPI package**, harvest **GitHub OAuth tokens**, and deploy the self-propagating **Shai-Hulud** worm across roughly **100 internal repositories**, stealing repository secrets and product source code. Note this variant is **PyPI, not npm**. The gap in the public write-up matters: **how the session was hijacked is not disclosed**, and there are no IOCs, no date and no named assistant vendor - so this cannot yet be turned into detection. Mandiant's controls are the actionable part: check AI-recommended dependencies against checksums and an approved allowlist, keep raw API keys and long-lived OAuth tokens out of extension reach, and route dependency traffic through controlled internal repositories.

PoC: Active exploitation in the wild - worm propagated across ~100 internal repos at an unnamed SaaS provider - cloud.google.com

Refs: cloud.google.com · thehackernews.com · bromure.io

PhantomRaven - LLM-generated npm infostealer harvesting CI/CD secrets to source bug bounty submissions

HIGH

VERIFIED

npm

AI-Generated

BountyAbuse

CrowdStrike Counter Adversary Operations attributes a JavaScript infostealer distributed through **100+ npm packages** to a financially motivated actor active since **November 2022**. Delivery uses a **remote dynamic dependency** - the package declares a dependency by HTTP URL, so npm fetches the payload from actor infrastructure - executed via preinstall. It harvests OS and host details, environment variables, Git/npm identities and **CI/CD secrets for GitHub Actions and equivalents**. The monetisation is the finding: the operator has collected bounties from **at least nine entities across Bugcrowd, Intigriti, YesWeHack, HackenProof and HackerOne**, and CrowdStrike has seen **no PhantomRaven logs for sale on log shops** - the stolen access appears to be used solely to source bounty submissions. **The victim pays the attacker, through a legitimate process, for access the attacker manufactured.** This is the second such case this month. Bug bounty programmes should add a provenance question to supply-chain report intake. Secondary but useful: the LLM-authorship call rests partly on the malware shipping the model's own placeholder hostname (`wss://yourserver.com/socket`) and boilerplate comments - AI-written malware is becoming ordinary, but it is also becoming identifiable.

PoC: Active exploitation in the wild - 100+ malicious npm packages; full IOC set published by CrowdStrike - crowdstrike.com

Refs: crowdstrike.com · thehackernews.com · hackread.com

Admin Menu Editor Pro - vendor site compromised, trojanized 2.35/2.36 backdoors ~1,500 WordPress sites

HIGH

VERIFIED

WordPress

SupplyChain

WebShell

An unauthorised party reached the **adminmenueditor.com** environment on **2026-09-14** and published a malicious **version 2.35**, available from roughly **06:00-13:00 UTC**; the attacker retained access and trojanized **2.36** as well. At least **230 customers installed it across ~1,500 sites**. The payload is **includes/wp-user-consent.php**, which starts a web shell and creates a **hidden administrator account**. Indicators: presence of `wp-user-consent.php`, a new object-cache directory, and hidden `wp_`-prefixed users and options. Because the attacker held access across two releases, **updating to the 'fixed' version is not sufficient** - the reliable remediation is restoring from a backup predating 2026-09-14, then rotating all site and hosting credentials. Note the published figures were initially inconsistent (1,500 sites vs 200+ customers); the reconciled numbers are ~230 customers / ~1,500 sites.

PoC: Active exploitation in the wild - malicious build served from the official vendor site for ~7 hours - bleepingcomputer.com

Refs: bleepingcomputer.com · cyberinsider.co.uk · windowsforum.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

BragJack - one browser extension hijacks the built-in AI assistant in five browsers (PoC released)

HIGH

VERIFIED

PoC

AI Agent

Extension

Gal Weizman (Forever Security) demonstrated that a single already-installed extension can seize the built-in AI assistant of **Chrome/Gemini Live, Perplexity Comet, Edge/Copilot, Opera Neon and Claude in Chrome** and reuse its privileges. **This is not prompt injection** - it is an architectural extension-to-agent isolation failure. The extension abuses Chromium's **declarativeNetRequest** API to intercept and redirect the agent's network traffic, executes code in the privileged assistant context, then applies **Prompt Forcing**: handing the agent a complete prompt and instruction set rather than smuggling content into one. Demonstrated impact includes reading local files, browsing history and screenshots, and forcing agents to exfiltrate email summaries; the Chrome path also reached camera and microphone with no user clicks. Two CVEs issued - **CVE-2026-0628** (Chrome/Gemini Live) and **CVE-2026-55945** (Edge, a race condition briefly disabling the Think/Do safeguard). All five vendors paid bounties totalling over **\$20,000**; all issues are resolved and **nothing has been seen in the wild**. The durable lesson: extension inventory and allow-listing is the control, because an agent's privileges become the extension's privileges.

PoC: Public - proof-of-concept extension and 'Prompt Forcing' technique published by Forever Security - bleepingcomputer.com

Refs: bleepingcomputer.com · thehackernews.com · darkreading.com

ipurple.team detection-engineering library - 25 adversarial techniques with SIGMA rules and Sysmon configs

INFO

UNVERIFIED

Tool

Detection

PurpleTeam

Panos Gkatziroulis marked a two-year milestone for the ipurple.team library: **25 documented adversarial techniques, each paired with SIGMA rules and the Sysmon configuration required to produce the telemetry those rules need.** The pairing is the point - it closes the common failure where a detection rule is deployed against telemetry that was never enabled. Directly deployable for purple-team exercises and detection-coverage gap analysis. **Single-source author announcement; retained as unverified** pending independent review of rule quality, as is standard for tool and PoC announcements in this report.

PoC: Public - 25 techniques, each shipping SIGMA rules and matching Sysmon configuration - [ipurple.team](#)

Refs: [ipurple.team](#)

Win11 26H2 phantom DLLs - xtajitse.dll and xtajitf.dll (new sideloading surface)

INFO

UNVERIFIED

Tool

Sideloading

RedTeam

Hexacorn's procmon pass over the Windows 11 **26H2** build identified two new phantom DLLs in the x86-on-ARM (xtajit) translation layer: **C:\Windows\System32\xtajitse.dll** and **xtajitf.dll**. These are libraries the OS attempts to load but which do not ship, which makes them a DLL-sideloading opportunity for an attacker with write access to System32 - and, symmetrically, a **zero-false-positive detection** for defenders, since a successful load of either file means someone placed it there. Add both paths to file-creation and image-load monitoring. **Single-source researcher post; corroboration not found, retained as unverified.**

PoC: Public - phantom DLL names published; zero-false-positive detection opportunity - [hexacorn.com](#)

Refs: [hexacorn.com](#)

GLOBAL - GUIDANCE & DEFENSIVE RESOURCES

Government guidance

CISA publishes guidance on deploying cyber decoys in critical infrastructure

INFO

VERIFIED

Guidance

Deception

Detection

CISA released guidance on deploying **cyber decoys** to detect adversaries already operating inside an environment, generate **high-fidelity alerts** and strengthen response, framed as complementary to Zero Trust rather than a substitute. The timing is instructive: it lands in the same week as a root-level Cisco ISE compromise in which the attacker can delete on-box indicators. **Decoys are one of the few controls that still fire when the compromised host's own telemetry cannot be trusted,** because the alert is generated off-host by definition. Low false-positive rate is the operational argument - a decoy touched is, by construction, unauthorised activity.

Refs: [securityweek.com](#) · [cisa.gov](#) · [blog.thinkst.com](#)

NCSC UK releases Cyber Adversary Simulation (CyAS) scheme documents ahead of November launch

INFO

VERIFIED

Guidance

Assurance

UK

The NCSC published the first **CyAS Scheme Standard and Working Practices Document**, setting out what is required of companies seeking NCSC-assured provider status - company requirements, mandated methodology and reporting standards - plus an accompanying 'Adversary simulation: what you need to know' explainer for buyers. **The scheme formally launches in November 2026,** with an initial cohort assessed over the 2026 northern summer. CyAS becomes a **third UK assurance scheme alongside CHECK and CBEST,** aimed at continuous, tailored reconnaissance and bespoke objective-led engagements rather than scoped penetration testing. Relevant to anyone procuring red-team services in the UK, and to providers who will need to decide whether to seek assurance.

Refs: [ncsc.gov.uk](#) · [ncsc.gov.uk](#) · [itpro.com](#)

GLOBAL - MALWARE & CAMPAIGNS

CHOSEN BRICK - Iranian state Windows implant with Telegram C2, targeting dissidents and journalists

HIGH

VERIFIED

APT

Iran

Spyware

A joint US/UK/Netherlands advisory exposed **CHOSEN BRICK**, an Iranian state Windows implant that copies emails and chat messages, takes screenshots and **activates the microphone**, using **Telegram as its command-and-control channel**. The documented lure was **fake MRI scan results** sent to a specific individual. Telegram C2 is the defensive problem: the victim population cannot afford to block it, and reputation-based controls do not apply to a legitimate service. Together with GRIMWEDGE (NGOs) and the Pixel modem zero-day (targeted attacks), that is **three distinct state capabilities aimed at individuals rather than enterprises in a single window**, each of which defeats the enterprise security model by targeting people who have no enterprise. NCSC publishing individual-facing protective advice alongside the technical analysis is the right shape of response and worth citing as a model.

PoC: Active exploitation in the wild - joint US/UK/NL government advisory - ncsc.gov.uk

Refs: ncsc.gov.uk · thehackernews.com · therecord.media

KREMLIN / REF9334 - Brazilian banking malware forges Chrome's own integrity checks to install an extension

HIGH

VERIFIED

Banking

Extension

Brazil

Elastic Security Labs has tracked REF9334 since **May 2025** across seven campaigns; the toolkit is named KREMLIN by its author (Kr3mlin4rt1st) and has **no Russian connection** - error strings and comments are Portuguese and the operators' Ethereum transactions cluster in Sao Paulo working hours. The technique is the notable part: KREMLIN installs a malicious Chrome/Edge extension **outside the Web Store** by force-closing the browser, extracting Chromium's **OSCrypt and App-Bound encryption keys via a debugged browser process**, then **regenerating the HMACs and encrypted hashes in Secure Preferences to forge the browser's own integrity checks** - so the browser loads it as though the user approved it. It impersonates twelve Brazilian banks and steals credentials and **session tokens**. C2 and payload locations are updated through **Ethereum smart contracts**, so infrastructure rotation needs no malware update and no seizable DNS. **1,515 infections confirmed, almost all in Brazil**. Extension inventory and allow-listing is the only durable control; integrity checks that the host can rewrite are not controls.

PoC: Active exploitation in the wild - 1,515 confirmed infections; Elastic published full IOCs - github.com

Refs: elastic.co · thehackernews.com · bleepingcomputer.com

Minnesota water utilities - 30+ systems attacked in 48 hours via internet-exposed PLCs with default credentials

HIGH

VERIFIED

OT

ICS

DefaultCreds

On **26-27 July 2026**, attackers reached the operational technology of **30+ Minnesota municipal water and wastewater systems**, using public scanning tools to find internet-exposed PLCs, logging in with **default manufacturer credentials**, then changing IP addresses, passwords and ladder logic until operators were locked out and blind. Reported effects included **loss of pressure and flooding**. The FBI identified **Rockwell Automation MicroLogix 1100 and 1400** controllers as the targets and confirmed similar intrusions in **at least seven states** within days; CISA issued **AA26-097A** urging every US water utility to remove controllers from the public internet. **There was nothing to exploit** - no malware, no CVE, no novel technique. Thirty victims in two days is a scanning operation, which means the exposed population is far larger than the victim count. Against a sector of roughly 148,000 largely unstaffed systems, this is an inventory-and-firewall problem that no amount of security product spend addresses.

PoC: Active exploitation in the wild - no malware and no CVE; default credentials on exposed controllers - tenable.com

Refs: tenable.com · securityaffairs.com · industrialcyber.co

Password-inside-the-attachment phishing defeats mail gateways and static AV

MEDIUM

VERIFIED

Phishing

Evasion

Gateway

Two variants of the same evasion landed this window. ANY.RUN documented a phish against a German manufacturer that passed **mail gateway filters and static AV because the decryption password was carried inside the PDF itself** - static extraction tools see /Encrypt objects and crypt-filter entries and stop, so the file is opaque to every automated tool in the delivery chain while remaining trivially openable by the victim. Separately, Clubic reported recruiters targeted through **genuine France Travail Pro platform emails** carrying a password-harvesting PDF CV: because the email really is from the platform, **SPF, DKIM, DMARC and sender reputation all pass correctly**. Both defeat the same assumption - that authentication and static scanning of the delivery path says something about the payload. The control that still works is detonation with the password supplied, plus user reporting; attachment-type policy is the blunt alternative.

PoC: Active exploitation in the wild - live campaigns passing gateway filters and static AV - ironscales.com

Refs: ironscales.com · clubic.com · ironscales.com

NightEagle, Hacking Cat and Toy Ghouls - three clusters hitting Russian enterprises with backdoors, ransomware and wipers

MEDIUM

UNVERIFIED

APT

Russia

Ransomware

Kaspersky documented three activity clusters against Russian enterprises. **NightEagle (APT-Q-95)**, active since at least 2023, gained access in most incidents using **compromised valid credentials on corporate VPNs**, with new persistence and lateral-movement techniques. **Hacking Cat** deployed **Gorilla RAT** and multiple **Monkey** ransomware variants against Windows, Linux and ESXi - though the group publicly disputed part of the attribution on its Telegram channel, saying the lockers are not theirs. **Toy Ghouls** (aka Bearlyfy, Laboo.bo0, Feral Wolf), financially motivated and active since 2025, has moved from leaked Babuk and LockBit builders to custom **GenieLocker** ransomware and now to a bespoke backdoor. Tooling across the three includes GhostContainer, ClearWater, Nemo Wiper and Bird Agent against Exchange and Active Directory. **Two sources only (Kaspersky primary plus one relay); the Securelist research was not retrieved and no TTPs or IOCs were recorded - retained as unverified.**

PoC: Active exploitation in the wild - Gorilla RAT, Monkey ransomware, Nemo Wiper, GhostContainer

Refs: thehackernews.com · securelist.com

Active scanning for /PIAF-HMS/ - abandoned hospitality PBX front end, distinctive user agent

MEDIUM

UNVERIFIED

Scanning

PBX

IOC

SANS ISC (Johannes Ullrich) reported scanning for **/PIAF-HMS/** - the PBX in a Flash Hospitality Management System, **abandoned for roughly ten years**, with no input validation, no authentication and no access control, and a recent SQL injection report. Scanning also probes **/admin/**, **/admin/config.php**, **/ucpl/**, **/hms/** and **/hotel/**. The IOCs are unusually clean: a single source IP **94.102.49[.]125** (IP Volume, AS202425, widely treated as bulletproof) and a custom User-Agent **Farez-Sorter/1.0** with no legitimate use - a zero-false-positive block and alert that costs nothing. Hotels are soft targets both for guest personal data and because a compromised PBX enables call interception and calls that appear to originate inside the victim organisation. **Single-source ISC diary; retained as unverified.**

PoC: Active scanning in the wild from a single source IP since 2026-09-15 - isc.sans.edu

Refs: isc.sans.edu

GLOBAL - NOTABLE BREACHES

AEPD (Spain) receives the first personal-data breach executed end-to-end by an AI agent

HIGH

VERIFIED

AI

Regulatory

First

Spain's data protection authority disclosed the **first notified personal-data breach carried out by design through an AI agent**. The reported stages: a scan of 'generic files', a successful **login**, an autonomous **vulnerability search**, then **personal data modified and invoices accessed**. The model, the product and the victim are all unnamed ('a known language model'). The AEPD's own conclusion is the operationally relevant one: **human supervision alone is not fast enough** against machine-tempo intrusion. Two caveats worth carrying: Infosecurity's 'AI Agent Carries Out Multi-Stage Data Theft Attack' is **the same incident, not a second one**, and independent commentary offers alternative explanations for the sequence - **so treat the agentic attribution as regulator-reported rather than forensically established**. Even discounted, it sets the precedent that regulators will now receive and categorise breaches this way.

Refs: securityweek.com · bleepingcomputer.com · clubic.com

Flock ALPR camera teardown - encryption key found on an unencrypted partition; models detect people, not just plates

HIGH

VERIFIED

Breach

Surveillance

KeyMgmt

The collective **stegan0gram** physically removed a Flock Safety automated licence plate reader and copied nearly all of its internal storage, handing the data to **404 Media and WIRED** for a joint analysis published 2026-09-16. The device runs Android and carried **two unencrypted partitions - vendor and media - and the media partition held the encryption key** for the encrypted footage archive. Recovered: roughly **21 days of data, ~50,200 vehicles, ~1.6 million images and 27,321 video clips**. The cryptography did not fail; **key storage did**. The larger finding is separate: WIRED extracted and ran the on-device models and found they **detect people, not only plates** - people appeared in 11 clips, all motorcyclists - which contradicts Flock's public position. Flock had previously told police customers that physical access alone would not expose footage, including in a 2025 response to root-access flaws CISA later rated 9.8. The company's response led with the illegality of the teardown; **fleet-wide key reuse has been neither confirmed nor denied, and no patch or key rotation has been committed**.

PoC: **Public - teardown methodology and findings published by 404 Media and WIRED - 404media.co**

Refs: 404media.co · wired.com · gadgetreview.com

CenterPoint Energy - customer data breach confirmed only after the actor leaked the data

HIGH

VERIFIED

Breach

Utility

Disclosure

CenterPoint Energy, the Houston electric and gas utility, confirmed a customer data breach **after** the threat actor published the data; the actor claims **7.5 million records**, which remains unverified. The disclosure sequence is the pattern worth recording - it matches IDScan, Revolut and the Florida DMV incident. **The victim organisation is no longer setting the disclosure timeline; the extortion forum is**. Incident response plans that assume the organisation controls announcement timing are planning for what has become the exception rather than the rule, and communications, regulatory notification and customer-support capacity all need to be pre-staged accordingly.

Refs: therecord.media · securityweek.com · bleepingcomputer.com

FBI seizes NightmareStresser - 566,000 users, hundreds of thousands of DDoS attacks since 2022

MEDIUM

VERIFIED

Takedown

DDoS

LawEnforcement

The FBI, coordinating with the Royal Canadian Mounted Police, seized **nightmare-stresser.com and nightmarestresser.org**, belonging to one of the longest-running DDoS-for-hire services. The seizure warrant affidavit states the platform was used for **hundreds of thousands of actual or attempted DDoS attacks since 2022**; researchers put it at **566,000+ users and 52 attack servers**. Victims span educational institutions, government agencies and gaming platforms. The action was supported by **Operation PowerOFF**. Booter takedowns historically produce a temporary dip rather than a durable reduction, so the practical value is the seized subscriber data - expect downstream enforcement, and expect displaced demand to reach competing panels within weeks.

Refs: helpnetsecurity.com · thehackernews.com · cybernews.com

Radaris loses radaris.com and 13 further people-search domains under New Jersey's Daniel's Law

MEDIUM

VERIFIED

OSINT

Privacy

Legal

A New Jersey court has transferred **14 domains** from the Radaris family of companies to **Atlas Data Privacy Corp** after the defendants repeatedly failed to appear; radaris.com now redirects to a notice of the court-ordered transfer. **Daniel's Law** requires commercial data brokers to remove information on judges, government personnel, law enforcement and their families, at **\$1,000 per violation**. Atlas says over **10,000 emails obtained in litigation** show Radaris and roughly 25 other people-search sites are run by the same small Boston-area group operating behind shifting shells in the Marshall Islands, BVI and Seychelles, and behind a fabricated CEO persona. The industry has moved at least **70 Atlas suits to federal court** on First Amendment grounds. **OSINT-relevant: a standard people-search pivot has changed hands** - treat continued availability of these domains as potentially instrumented, and re-validate any tooling that queries them.

Refs: krebsonsecurity.com · yahoo.com · archyde.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
94.102.49[.]125	IP	Sole source IP scanning for /PIAF-HMS/ (IP Volume, AS202425, bulletproof)	isc.sans.edu
Farez-Sorter/1.0	User-Agent	PIAF-HMS scanner UA - no legitimate use; zero-false-positive block	isc.sans.edu
/PIAF-HMS/ , /ucp/ , /hms/ , /hotel/	URI paths	Hospitality PBX scan target set; search web logs back to 2026-09-10	isc.sans.edu
54.173.15[.]59	IP	PhantomRaven npm infostealer C2	crowdstrike.com
packages[.]storeartifact[.]com	Domain	PhantomRaven remote dynamic dependency / payload host	crowdstrike.com
registry[.]storageartifact[.]com	Domain	PhantomRaven C2 / payload host	crowdstrike.com
packages[.]storageartifact[.]com	Domain	PhantomRaven C2 / payload host	crowdstrike.com
npm[.]jpartifacts[.]com	Domain	PhantomRaven C2 / payload host	crowdstrike.com
c31831d47fcbf52ff1f4e61838611916a4276d005a564e69946d5dac04235eed	SHA256	PhantomRaven infostealer sample	crowdstrike.com
95a7dcc6de46826b22c43bee7fc550f3b5e2e6cbc5f33b0c241faf523641cf63	SHA256	PhantomRaven infostealer sample	crowdstrike.com
db3fe46df0a65fe9f8c99d2e11126a032a72e9814e354ce017448ce088a01e02	SHA256	PhantomRaven infostealer sample	crowdstrike.com
transform-jsbi-to-bigint , sort-imports-es6-autofix	npm packages	PhantomRaven delivery packages (users jpdhellonpm1 / jpd15)	thehackernews.com
includes/wp-user-consent.php	Filename	Admin Menu Editor Pro 2.35/2.36 web shell; plus new object-cache dir and hidden wp_ users	bleepingcomputer.com
wwlc_file_upload_handler	AJAX action	WooCommerce Wholesale Lead Capture unauth upload endpoint (CVE-2026-27540)	infosecurity-magazine.com
/pbxapi/manager/originate + System app	URI / AMI call	Issabel forged-JWT command execution (CVE-2026-89026)	thehackernews.com
xtajitse.dll , xtajitf.dll	Filenames	Win11 26H2 phantom DLLs in System32 - any successful load is malicious	hexacorn.com
CVE-2026-76460	CVE	Cisco ISE API auth bypass to root (10.0); KEV, BOD 26-04 3-day deadline	bleepingcomputer.com
CVE-2026-5430	CVE	WSO2 API Manager forged admin JWT (9.8); exploited from 2026-09-13	securityweek.com

Indicator	Type	Context	Reference
CVE-2026-59310	CVE	VMware vCenter Syslog traversal to RCE (9.8); KEV, ransomware	bleepingcomputer.com
CVE-2026-58704	CVE	Pixel modem privilege escalation; KEV 2026-09-16, due 2026-09-19	securityweek.com
CVE-2026-85046 , CVE-2026-87491 , CVE-2026-85880	CVEs	Chrome + Windows ALPC chain used by UTA0560 and JungleBamboo	volexity.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Token forgery and skipped signature checks as the dominant auth-bypass class

Why it matters: Four unrelated products failed the same way in one window - Cisco ISE (API authorisation), WSO2 (JWT signed with an unsupported algorithm), Issabel (hard-coded HS256 key shared across every install), following JFrog Artifactory's admin-token minting. Token issuance and token validation is now the recurring failure site on control-plane products. Every control downstream of identity is bypassed by construction, and exploitation produces authentication successes rather than failures, so failed-login telemetry sees nothing.

Watch for: JWTs with anomalous alg, kid or iss values; admin-scope API calls from unfamiliar source IPs or user agents; new API subscriptions, applications or policy changes; any control-plane product where you cannot state how token signatures are verified. Audit your own JWT validation paths for algorithm confusion, unverified kid lookup and signature checks skipped on a code branch.

HIGH

Shared hosting as a single blast radius - four issues, one chain

Why it matters: LiteSpeed Enterprise (tenant to root, bypasses CageFS) and the exploited Acronis cPanel plugin (CVE-2026-87886, local root) each turn one hosting account into the whole server. In the same window, The Events Calendar, WooCommerce Wholesale Lead Capture and the Admin Menu Editor Pro supply-chain compromise each deliver exactly the low-privilege foothold those escalations need. Patching any one of the four leaves the chain intact.

Watch for: PHP files written under wp-content/uploads; wp-user-consent.php and hidden wp_-prefixed users; cross-tenant file access on shared hosts; LiteSpeed Enterprise below 6.3.7 and unpatched Acronis plugins. Note OpenLiteSpeed had no matching fix as of 15 September.

HIGH

AI systems as the intrusion path, not just the target

Why it matters: Four independent cases this week: a hijacked AI coding-assistant session that recommended a poisoned dependency and led to Shai-Hulud across ~100 repos; the first agentic breach notified to a regulator (AEPD); an LLM-written npm stealer whose operator launders stolen CI/CD secrets through the victims' own bug bounty programmes; and BragJack, where one extension seizes the built-in AI assistant in five browsers via an extension-to-agent isolation failure rather than prompt injection.

Watch for: AI-recommended dependencies accepted without checksum or allowlist verification; long-lived OAuth tokens and raw API keys reachable by extensions or agents; browser extension inventory drift; agents acting on untrusted inbound content without human-in-the-loop; supply-chain bug bounty reports with unexplained access provenance.

HIGH

Patch volume and patch quality have crossed

Why it matters: Microsoft shipped 974 CVEs this month, Oracle 672 and Apple 261 - and in the same cycle Microsoft issued out-of-band fixes for RDS, Hyper-V and USB audio regressions, silently broke Excel copy/paste, and broke domain trust with KB5124008. A security update that breaks remote administration creates direct pressure to uninstall the security update, precisely when the patch-to-exploit window is shortest. 'Patch faster' is now in measurable tension with observable patch reliability.

Watch for: regression reports in your own change records; staged-ring deployment coverage; whether your emergency-patch process can distinguish a three-day KEV deadline (Cisco ISE, Pixel, vCenter) from routine rollout. For Oracle, triage the 78 unauthenticated network-exploitable Fusion Middleware issues rather than the 672 headline.

MED

State capability aimed at individuals, not enterprises

Why it matters: CHOSEN BRICK (Iran, Telegram C2, microphone activation, fake-MRI lure), GRIMWEDGE (China-linked UTA0560, NGOs, chained Chrome/Windows n-days shared with APT31) and the exploited Pixel modem flaw are three distinct capabilities targeting people rather than organisations in a single window. Each defeats the enterprise security model by targeting people who have no enterprise. Telegram C2 compounds this: the victim population cannot afford to block it, so reputation controls do not apply.

Watch for: Telegram and other consumer-service traffic from hosts with no business reason for it; unpatched Chrome and Windows on personally managed devices; NGO, journalist and diaspora-facing staff without managed endpoints. NCSC's pairing of individual-facing protective advice with technical analysis is the model to copy.

MED

Internet-exposed OT needs no vulnerability at all

Why it matters: Thirty-plus Minnesota water systems were taken over in 48 hours with no malware, no CVE and no novel technique - public scanning tools found exposed Rockwell MicroLogix PLCs, default manufacturer credentials got the attacker in, and IP and password changes locked operators out, causing pressure loss and flooding. Thirty victims in two days is a scanning operation, which means the exposed population is far larger than the victim count.

Watch for: any PLC, HMI or RTU reachable from the internet; default or absent controller credentials; unexplained controller IP or ladder-logic changes; vendor remote-access paths into OT. Against ~148,000 mostly unstaffed US water systems this is an inventory-and-firewall problem, not a detection or product problem.

MED

Delivery-path authentication says nothing about payload safety

Why it matters: Two phishing variants this week defeated the same assumption. A password carried inside the PDF itself made the attachment opaque to gateway filters and static AV while remaining trivially openable by the victim. Separately, recruiters were targeted through genuine France Travail Pro platform emails, so SPF, DKIM, DMARC and sender reputation all passed correctly - because the email really was from the platform.

Watch for: encrypted attachments where the password appears in the message body or the file; inbound from legitimate platforms carrying user-supplied attachments; reliance on sender authentication as a payload verdict. Detonation with the supplied password, plus a working user-reporting path, are the controls that still function.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	Cisco ISE / ISE-PIC to 3.1 P12 / 3.2 P11 / 3.3 P12 / 3.4 P7 / 3.5 P4 (CVE-2026-76460, no workaround, KEV 3-day); WSO2 API Manager (CVE-2026-5430); VMware vCenter (CVE-2026-59310); Issabel to commit b97dbaf0 or later; The Events Calendar 6.17.4.1; WooCommerce Wholesale Lead Capture 2.0.3.2; LiteSpeed Enterprise 6.3.7; Acronis cPanel plugin; Pixel September release (CVE-2026-58704); BIND 9.20.29 / 9.21.26 / 9.20.29-S1; TP-Link Tapo C200 firmware V5_1.4.6; Oracle CSPU - Fusion Middleware first.
Block IOCs	Add every indicator in the IOC table to firewall, proxy, EDR and SIEM blocklists: 94.102.49[.]125 and User-Agent Farez-Sorter/1.0 (zero false positives); PhantomRaven C2 IP, four domains and three SHA256 hashes; the two npm package names; file indicators wp-user-consent.php, xtajitse.dll and xtajitf.dll; and alert on the listed CVE IDs in vulnerability scan output. Re-fang before importing.
Assume compromise	Treat internet-exposed Cisco ISE, WSO2 API Manager, Issabel and vCenter as potentially compromised. For ISE specifically: pull access.log from every node before patching, cross-check external network telemetry, and re-image rather than clean - root execution means on-box logs are not evidence of absence. For WSO2, rotate the signing keypair and every credential the gateway holds or issues; patching does not invalidate already-forged tokens.
Shared hosting	Triage LiteSpeed, Acronis and the three WordPress issues as one chain, not five items. Enumerate plugin versions across every hosted site; audit for cross-tenant access; restore Admin Menu Editor Pro sites from a backup predating 2026-09-14 rather than updating; note OpenLiteSpeed still had no fix as of 15 September.
AI and developer supply chain	Verify AI-recommended dependencies against checksums and an approved allowlist; route dependency traffic through internal repositories; keep raw API keys and long-lived OAuth tokens out of extension and agent reach; inventory and allow-list browser extensions; add a provenance question to bug bounty supply-chain report intake.
OT and IoT	Confirm no PLC, HMI or RTU is reachable from the internet and that no controller retains default credentials - Rockwell MicroLogix 1100/1400 specifically. Segment cameras and IoT off flat networks; the third TP-Link Tapo flaw remains unpatched.
Detection engineering	Deploy decoys per the new CISA guidance - they alert off-host, which matters when a root compromise can delete local indicators. Alert on Telegram and MQTT traffic from hosts with no business reason for it. Monitor image-load and file-creation for the two Win11 26H2 phantom DLLs.
People and process	Brief staff on password-inside-the-attachment phishing and on lures arriving from genuine platform senders. Pre-stage breach communications on the assumption that the extortion forum, not the organisation, sets the disclosure timeline.